

Mapeo de Preguntas a Requisitos Normativos

Nº	Bloque / Pregunta resumida	Referencias normativas y guías principales
1	Modelo de gobernanza de protección de datos y seguridad	RGPD arts. 5, 24, 25, 32; ISO 27001; ISO 27701 (accountability, gobernanza) [web:23][web:27]
2	Designación de DPO, CISO, comités	RGPD arts. 37–39; prácticas de gobernanza; NIS2 roles de gestión de riesgos [web:22] [web:26]
3	Reporting periódico a la alta dirección	RGPD art. 24; ISO 27001 cláusulas de liderazgo; NIS2 obligaciones de gestión [web:22] [web:26][web:23]
4	ROPA y vinculación con medidas de seguridad	RGPD arts. 30, 32; ENISA Handbook – Security of Personal Data Processing [web:25][web:28]
5	Frecuencia de actualización del ROPA	RGPD art. 30(1)-(2); principio de exactitud y actualización [web:28]
6	Existencia de metodología formal de análisis de riesgos	RGPD arts. 24, 32; ENISA guías de evaluación de riesgos; ISO 27005 [web:25][web:28]
7	Escalas de impacto sobre derechos y libertades	RGPD considerandos 75–76; doctrina sobre enfoque basado en el riesgo [web:9][web:28]
8	Porcentaje de tratamientos con análisis de riesgos	RGPD arts. 24, 25, 32; ENISA Handbook (cobertura de análisis) [web:25]
9	Procedimiento para decidir EIPD/DPIA	RGPD arts. 35–36; listas AEPD y otras autoridades [web:25] [web:28]
10	Cobertura de EIPD	RGPD art. 35; ISO 27701 (gestión de riesgos de privacidad) [web:23][web:27]
11	Actualización de EIPD tras cambios e incidentes	RGPD arts. 24, 35(11); enfoque de ciclo de vida del riesgo [web:9][web:28]
12	Política de cifrado	RGPD art. 32(1)(a) (cifrado); guía AEPD sobre sistemas criptográficos [web:21][web:28]
13	Cifrado en reposo	RGPD art. 32; EDPB casos sobre cifrado e impacto en brechas [web:14][web:21]

14	Cifrado en tránsito	RGPD art. 32; ENISA recomendaciones técnicas [web:25][web:21]
15	Autenticación multifactor (MFA)	RGPD art. 32; NIS2 medidas de seguridad; buenas prácticas ENISA [web:22][web:26] [web:25]
16	Pseudonimización	RGPD art. 4(5), 25, 32; ENISA / AEPD buenas prácticas [web:25] [web:28]
17	Segmentación de redes	RGPD art. 32; NIS2 requisitos técnicos; ENISA guías de seguridad [web:22][web:26] [web:25]
18	Monitorización continua (SIEM/SOC)	RGPD art. 32(1)(b); NIS2 (detección de incidentes); ENISA incident reporting [web:22][web:26][web:25]
19	Tiempo medio de parcheo de vulnerabilidades	RGPD art. 32 (gestión de vulnerabilidades); ENISA guías técnicas [web:25][web:28]
20	Hardening de sistemas	RGPD art. 32; ISO 27001 Anexo A (controles técnicos) [web:23]
21	Procedimiento de gestión de incidentes y brechas	RGPD arts. 33–34; ENISA guías de gestión de incidentes [web:25][web:28]
22	Registro sistemático de incidentes	RGPD art. 33(5); ENISA recomendaciones de registro [web:14][web:25]
23	Número de brechas notificadas	RGPD arts. 33–34; práctica de autoridades (AEPD, otras) [web:6][web:11][web:14]
24	Tiempo hasta la detección	RGPD art. 32; EDPB digest seguridad del tratamiento [web:14]
25	Tiempo hasta la notificación	RGPD art. 33(1) (“sin dilación indebida y, de ser posible, a más tardar 72 horas”) [web:28] [web:14]
26	Eficacia de medidas técnicas en brechas	RGPD arts. 32, 34(3); EDPB casos donde cifrado reduce obligaciones [web:14][web:21]
27	Evaluación de proveedores y encargados	RGPD art. 28; ISO 27701 (riesgo de terceros) [web:23][web:27]
28	Certificaciones de proveedores	RGPD art. 28(1); uso de certificaciones como garantías adicionales [web:27][web:23]

29	Monitorización de postura de seguridad de proveedores	RGPD arts. 28, 32; NIS2 evaluación de cadena de suministro [web:22][web:26]
30	Nivel de formación en protección de datos y ciberseguridad	RGPD art. 39(1)(b) (DPO); art. 32 (factor humano); ENISA awareness [web:25]
31	Cobertura de formación	RGPD principio de responsabilidad proactiva; ISO 27001 (competencia) [web:23] [web:27]
32	Métricas de comportamiento (phishing, reporte)	RGPD art. 32; NIS2 gestión de riesgos operativos [web:22] [web:26]
33	Existencia de cuadro de mando de ciberseguridad y protección de datos	RGPD art. 24 (accountability); ISO 27701 (evidencias de cumplimiento) [web:27]
34	Indicadores reportados a dirección	RGPD art. 24; modelos de gobernanza y reporting [web:23][web:27]
35	Métricas de madurez alineadas con NIS2/ISO	NIS2; ENISA NIS360; ISO 27001/27701 madurez [web:22] [web:26][web:27]
36	Cálculo de costes y ROI de seguridad y cumplimiento	RGPD art. 32 (proporcionalidad de medidas); análisis económico de riesgo [web:12][web:28]
37	Sanciones y apercibimientos recibidos	RGPD arts. 58–83; estadísticas de AEPD y otras autoridades [web:6][web:11][web:3]
38	Investigaciones transfronterizas (OSS)	RGPD arts. 60–67; EDPB casos OSS seguridad/brechas [web:14]
39	KPIs de remediación tras incidentes o sanciones	RGPD art. 24; enfoque de mejora continua [web:23][web:27]
40	Uso de IA con datos personales	RGPD arts. 5, 24, 25, 35; orientación recent sobre IA y datos; ISO 27701 [web:27] [web:28]
41	EIPD específicas para sistemas de IA	RGPD art. 35; guías de EIPD; enfoque de riesgo elevado [web:9][web:28]